Database Security Policy

Policy Number: IT-SEC-DB-001

Classification: Confidential — Internal Use Only

Effective Date: March 24, 2026

Review Cycle: Annual

Policy Owner: Lead Database Administrator

Approved By: Chief Information Security Officer (CISO)

Table of Contents

Purpose and Scope 3

Defense-in-Depth Framework 3

Security Management 4

Physical Security 5

Network Security 6

Database Security 7

Access Control 8

Vendor and Third-Party Access Control 10

Data Access and Auditing 11

Incident Response 12

Compliance and Enforcement 13

Roles and Responsibilities 13

Purpose and Scope

This policy establishes the database security standards for *Tech Company*, a corporation of approximately 1,500 employees with annual net sales of $250 million, growing at approximately 10% per year. As the organization scales, the protection of data assets becomes increasingly critical.

This policy governs all Microsoft SQL Server database environments managed internally, as well as the third-party cloud-hosted HR system. It applies to all employees, contractors, vendors, and any third party who accesses, administers, or interacts with corporate database systems. The policy is built on the principle of **defense in depth** — the implementation of multiple, overlapping layers of security controls so that the failure of any single control does not result in a breach.

Defense-in-Depth Framework

Defense in depth recognizes that no single security measure is sufficient. This policy establishes the following layered security model:

Layer	Domain	Focus
Layer 1	Security Management	Governance, policy, risk, vendor oversight, personnel
Layer 2	Physical Security	Data center access, hardware protection
Layer 3	Network Security	Firewalls, segmentation, and encryption in transit
Layer 4	Database Security	SQL Server hardening, architecture, and encryption at rest
Layer 5	Access Control	Authentication, authorization, and least privilege
Layer 6	Data Access & Auditing	Logging, monitoring, alerting

Each layer is addressed in detail in the sections that follow. A breach must penetrate all applicable layers, making unauthorized access exponentially more difficult.

Security Management

Policy Governance

The Lead DBA, in coordination with the CISO and IT management team, is responsible for the development, enforcement, and annual review of this policy. Any exceptions to this policy must be documented, risk-assessed, and approved in writing by the CISO.

Risk Management

A formal database risk assessment shall be conducted at least annually, or whenever a significant change occurs in the environment (e.g., new applications, mergers, regulatory changes). Risk assessments shall identify threats from both **external actors** (hackers, cybercriminals) and **internal actors** (employees, contractors, vendors), as insider threats represent an equally significant risk vector.

Insider Threat Recognition

The organization acknowledges that insiders — including current employees, former employees, and trusted third parties — pose a substantial threat to database security. Common insider threat scenarios include:

- A disgruntled employee exfiltrating customer or financial data before termination.
- A DBA abusing elevated privileges for personal gain.
- A vendor with overly broad access intentionally or accidentally exposes data.
- A departing employee retains credentials after their last day.

Controls throughout this policy are specifically designed to mitigate insider threats, not only external ones.

Separation of Duties

No single individual shall have end-to-end control over a sensitive data process without oversight. Specifically:

- Database administrators shall not also serve as application developers on production systems.
- Access provisioning shall require approval from both IT and the requesting employee's manager.
- Privileged account usage shall be logged and reviewed by a party independent of the DBA team.

Security Awareness Training

All employees with any level of database access must complete annual security awareness training covering phishing, social engineering, password hygiene, and data handling. DBAs and system administrators must additionally complete role-specific training on SQL Server security hardening and vulnerability management.

Physical Security

Data Center Access Controls

All servers hosting SQL Server databases must be housed in a secure data center or server room with the following minimum controls:

- Multi-factor physical access (key card + PIN, or biometric) required to enter server rooms.
- Access logs maintained for all entries and exits, retained for a minimum of 12 months.
- Visitors and vendors must be escorted at all times and logged in a physical visitor register.
- Security camera coverage of all server room entry points, with footage retained for 90 days.

Hardware and Media Controls

- Servers must be racked and physically secured; individual drives must not be removable without authorization.
- Decommissioned storage media must be degaussed or physically destroyed before disposal — no media leaves the facility without a signed destruction certificate.
- Portable media (USB drives, external hard disks) are prohibited from use on database servers unless explicitly approved by the CISO for a specific, documented purpose.

Environmental Controls

- Server rooms must maintain redundant power (UPS and generator), temperature monitoring, fire suppression, and flood detection
- Environmental alerts must be routed to on-call personnel 24/7

Network Security

Network Segmentation and Architecture

Critical architectural requirement: The database server and the web server must reside on separate physical or virtual machines and in separate network segments. Placing a database server on the same host as a web server is a significant security exposure — a compromise of the web-facing application would provide direct local access to the database. This configuration is strictly prohibited.

The required architecture is as follows:

- The web server resides in a DMZ (Demilitarized Zone), separated from the internet by a perimeter firewall.
- The database server resides on a separate, isolated internal network segment behind an internal firewall.
- No direct connection from the internet to the database segment is permitted under any circumstances.
- Database servers shall have no internet access unless explicitly required and approved in writing by the CISO.

Firewall Rules

- Default deny: all traffic to the database network segment is denied unless explicitly permitted.
- Only the application server(s) may connect to the database server, and only on the designated SQL Server port.
- Administrative connections to the database server shall be limited to DBA workstations by IP address.
- Firewall rules shall be reviewed quarterly, and any rules no longer required must be removed promptly.

Encryption in Transit

- All connections between the application tier and the database server must use TLS 1.2 or higher.
- SQL Server must be configured to force encrypted connections; unencrypted connections must be rejected.
- Connections to the cloud-hosted HR system must also use TLS 1.2 or higher and must be validated against a trusted certificate authority.

Intrusion Detection and Prevention

- Network-based IDS/IPS must monitor traffic on all segments containing database servers.
- Alerts for anomalous query volumes, unusual connection times, or connections from unauthorized sources must be routed to the security operations function.
- IDS/IPS signatures and rules must be updated at least monthly.

Remote Access

- Remote database administration is permitted only through an approved VPN with multi-factor authentication.
- Direct RDP or SSH to database servers from outside the corporate network is prohibited.
- VPN access logs for database server connections shall be retained for 12 months.

Database Security

SQL Server Hardening

All MS SQL Server instances must be hardened upon deployment and verified against a hardening checklist annually. Minimum hardening requirements:

- Remove or disable all unused features, endpoints, and services (e.g., SQL Server Browser, xp_cmdshell, linked servers unless specifically required).
- Apply all Microsoft security patches within 30 days of release; critical patches within 72 hours.
- Rename or disable the built-in SA (System Administrator) account.
- Disable the SQL Server guest account in all user databases.
- Set SQL Server to use Windows Authentication mode; mixed-mode authentication must be justified and approved in writing.

Separate Database and Web Servers

As stated in the Network Security section, the database server must be separate from the web server. This is a non-negotiable architectural control. The application must connect to the database using a dedicated, least-privileged service account — not a shared or administrative account.

Port and Protocol Hardening

- SQL Server should be configured to use a non-default port (not 1433) to reduce automated scanning exposure.

- SQL Server Browser service should be disabled where static ports are used.
- Named pipes should be disabled; TCP/IP only should be used for network connectivity.

Encryption at Rest

- All databases containing sensitive data (financial, employee, customer, or PII) must use SQL Server Transparent Data Encryption (TDE).
- Encryption keys must be stored separately from the data they protect and managed through SQL Server's Extensible Key Management (EKM) or an equivalent key management system.
- Backups of encrypted databases must remain encrypted; backup encryption must be verified at each backup job.

Database Backup and Recovery

- Full database backups must occur daily; transaction log backups must occur at a minimum every 60 minutes for production systems.
- Backups must be stored in a location separate from the production database server, with access restricted to authorized DBAs.
- Recovery procedures must be tested at least annually; recovery time and recovery point objectives must be documented and met.

Cloud-Hosted HR System

The third-party cloud HR system is subject to the following additional requirements:

- The vendor must provide a current SOC 2 Type II report annually.
- A Data Processing Agreement (DPA) and information security addendum must be in place and reviewed annually.
- Connectivity to the cloud HR system must route through the corporate network where technically feasible.
- Employee data synchronized between the HR system and internal systems must use encrypted channels and be stored in an access-controlled internal database.

Access Control

Principle of Least Privilege

All database accounts — whether user, application, or administrative — must be granted only the minimum permissions required to perform their defined function. This applies to application service accounts, end-user reporting accounts, and DBA accounts. Permissions must be assigned to roles, not to individual accounts, wherever possible.

Authentication Requirements

- All database accounts must use strong passwords: minimum 14 characters, complexity enabled, 90-day maximum age.
- Multi-factor authentication is required for all DBA-level access to production SQL Server instances.
- Shared database accounts are prohibited; every individual must have a uniquely identified account.
- Service accounts must use long, randomly generated passwords managed through an approved password vault.

Privileged Access Management

- DBA team members must have separate standard and privileged accounts — day-to-day tasks must be performed on standard accounts.
- Privileged account usage (sysadmin, db_owner) must be logged and justified.
- The list of accounts with sysadmin or db_owner roles must be reviewed monthly by the Lead DBA and CISO.

Access Provisioning

All database access requests must follow a formal provisioning process: the employee or manager submits a written request specifying the system, access level, and business justification; the DBA team reviews for least-privilege compliance; the employee's direct manager approves; access is provisioned and documented in the access register; and access is reviewed at a minimum every 90 days.

User Termination and Offboarding — Turnover Controls

Employee turnover represents one of the highest-risk events for database security. The following controls are mandatory:

- **Voluntary or involuntary termination:** All database accounts must be disabled within four hours of HR notifying IT of a separation. For terminations deemed high-risk (involuntary, performance-based, or involving employees with privileged access), accounts must be disabled before or concurrent with the employee being notified.
- **Offboarding checklist:** HR must notify the DBA team as part of the standard offboarding workflow. The DBA team maintains a database-specific offboarding checklist covering: disabling all accounts, revoking service account access, rotating any shared secrets the employee knew of, and reviewing audit logs for unusual activity in the 30 days prior to departure.
- **Password rotation:** Any shared credentials or service account passwords known to the departing employee must be rotated within 24 hours.

- **Access log review:** Audit logs for the departing employee's accounts must be reviewed for the 60 days prior to termination, and any anomalies must be escalated to the CISO.
- **Contractor and vendor access:** Contractor access must be time-bound at provisioning and automatically expire at the end of the engagement. Vendor access must be reviewed upon any change in the vendor relationship.

Periodic Access Reviews

- All database access accounts must be reviewed at minimum every 90 days.
- Managers must certify that each of their employees' access levels remain appropriate.
- Any account not recertified within the review window is automatically disabled.
- Accounts with no login activity in 60 days must be disabled pending review.

Vendor and Third-Party Access Controls

Vendor Access Policy

Third-party vendors, managed service providers, and contractors represent a significant risk surface. The following controls apply to all third parties with any level of access to corporate database systems:

- All vendor access must be formally documented, approved by the CISO, and limited in scope and duration.
- Vendors must sign a Data Processing Agreement and adhere to this policy as a contractual condition.
- Vendors must not have standing (always-on) access to production databases; access must be provisioned on demand and deprovisioned immediately when the session or task is complete.
- Vendor sessions on production systems must be logged and, where technically feasible, recorded.

Vendor Risk Assessment

Before granting any vendor access to database systems, the vendor must complete a security questionnaire and provide evidence of relevant certifications (SOC 2, ISO 27001, or equivalent). Vendor risk assessments must be renewed annually for ongoing vendor relationships. Vendors with access to systems containing PII or financial data are subject to enhanced due diligence.

Cloud Provider — HR System

The third-party HR cloud provider is subject to an annual SOC 2 Type II audit report review, a right-to-audit clause in the contract, notification requirements for any security incident affecting

company data within 24 hours of the vendor's discovery, and an annual review of the vendor's data retention and deletion practices.

Vendor Offboarding

Upon termination of any vendor relationship, all vendor accounts must be disabled on or before the last day of the engagement, any vendor-specific credentials or access tokens must be rotated, data shared with the vendor must be returned or certified as destroyed per the contract terms, and a final access log review must be conducted and retained for 12 months.

Data Access and Auditing

Audit Logging Requirements

SQL Server auditing must be enabled on all production instances. The following events must be logged at a minimum:

- All successful and failed login attempts
- All DDL changes (CREATE, ALTER, DROP on tables, stored procedures, views, logins)
- All access to tables containing sensitive data (PII, financial records, HR data)
- All changes to security configurations, permissions, and roles
- All use of privileged accounts (sysadmin, db_owner)
- All backup and restore operations
- Failed permission checks (access denied events)

Log Retention

- Database audit logs must be retained for a minimum of 12 months in an accessible state, and an additional 24 months in archived storage.
- Logs must be stored in a location where database administrators cannot modify or delete them.
- Log integrity must be protected through hashing or other tamper-evident mechanisms.

Log Review and Alerting

Automated alerting must be configured for the following events, with alerts routed to the security team within 15 minutes: login failures exceeding five attempts within 10 minutes on any account; any login attempt using the SA account or any disabled account; any schema change on a production database outside of an approved change window; any connection attempt from an unauthorized IP address; and bulk data export operations by a non-application account. A designated member of the DBA or security team must review audit logs at minimum weekly, and reviews must be documented.

Data Classification

Data stored in corporate databases must be classified and logged according to the following framework:

Classification	Examples	Logging Requirement
Restricted	PII, financial records, HR data, credentials.	All read and write access is logged.
Confidential	Internal business data, pricing, and contracts.	Write access and bulk reads logged.
Internal	Operational reports, non-sensitive records.	Failed access and schema changes logged.
Public	Published product data	Failed access logged

Incident Response

Database Security Incidents

The following events constitute database security incidents and must be reported to the CISO immediately: unauthorized access to any database (confirmed or suspected); exfiltration of data from any database system; discovery of unauthorized accounts or privilege escalation; loss or theft of backup media containing database data; and any security incident at the cloud HR provider affecting company data.

Response Procedures

Upon detection of a suspected incident, the response sequence is: contain the affected system by isolating it from the network if active exfiltration is suspected; preserve audit logs and forensic evidence before any remediation; notify the CISO and activate the Incident Response team; investigate root cause and engage forensic support if needed; remediate by closing the vulnerability, rotating credentials, and restoring from clean backups if necessary; and conduct a post-incident review within 14 days with policy controls updated accordingly.

Compliance and Enforcement

Violations of this policy may result in disciplinary action up to and including termination of employment or contract. Violations that result in regulatory penalties or legal liability may be referred to legal counsel. All violations must be reported to the CISO. This policy shall be reviewed annually, or following any significant security incident, material change in the technology environment, or applicable regulatory change.

Roles and Responsibilities

Role	Key Responsibilities
CISO	Policy approval, exception approval, and incident escalation
Lead DBA	Policy ownership, access reviews, audit log review, vendor oversight
DBA Team	Day-to-day enforcement, provisioning, hardening, and monitoring
IT Management	Budget for security controls, staffing, and infrastructure architecture
HR	Timely notification of all employee status changes to IT
Managers	Access request approvals, 90-day access recertifications
All Employees	Compliance with access controls, reporting suspected incidents
Vendors	Contractual compliance, security questionnaire, SOC 2 evidence

This document is the property of *Tech Company*. Unauthorized distribution is prohibited.
IT-SEC-DB-001 | Version 1.0 | Effective March 24, 2026